

# Network Security

## Network Security Report

GitHub Link : <https://github.com/dev-69/secure-chat-laughing-engine>

## Phase 1 – Baseline Chat Application

### 1. System Overview

Phase 1 implements a basic one-to-one chat application using TCP sockets. The system consists of two programs:

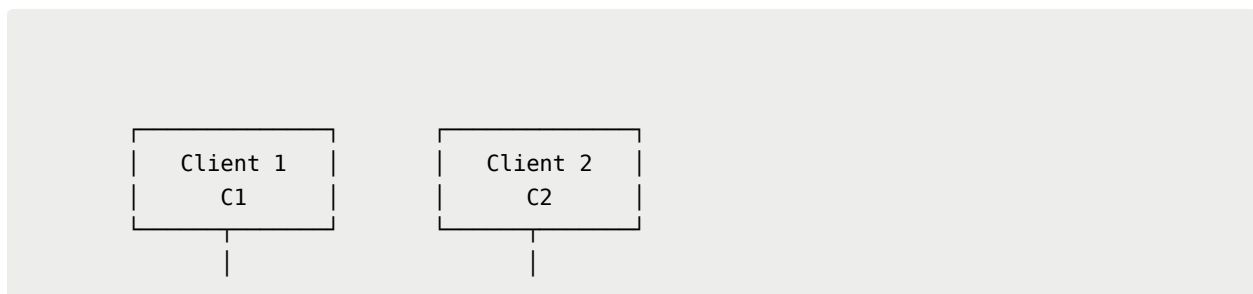
- `server.cpp` – handles client connections and forwards messages.
- `client.cpp` – provides the interface used by each client.

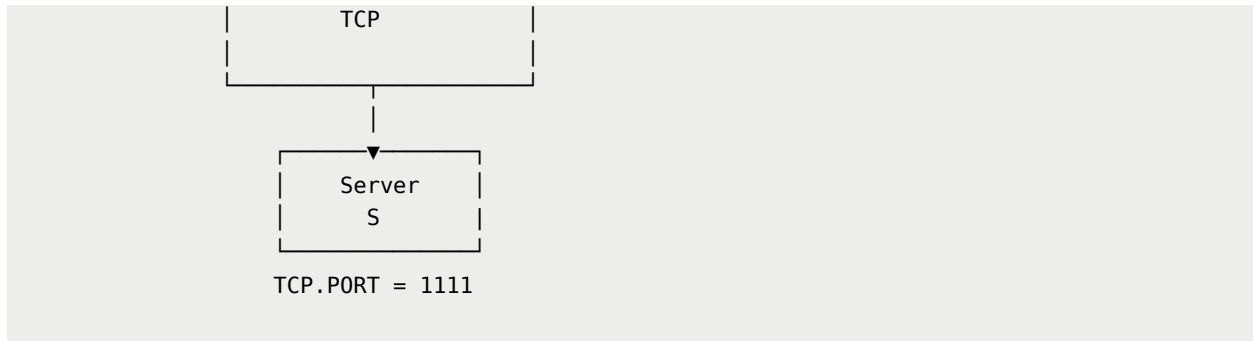
The server listens for TCP connections on **port 1111**. Two clients can connect to the server at the same time and communicate through it.

The application was tested using **three separate physical laptops connected to the same network**. One laptop was used as the server and the other two were used as clients.

### 2. System Architecture

The communication follows the architecture below:





The server keeps track of connected clients and forwards each message to the intended recipient.

---

### 3. Server Implementation

The server creates a TCP socket, binds it to port `1111`, and starts listening for incoming connections.

Each new client connection is handled using a separate thread:

```
std::thread clientThread(handleClient, clientSocket);
clientThread.detach();
```

This allows multiple clients to stay connected and communicate concurrently.

The server maintains a mapping between usernames and socket descriptors:

```
std::unordered_map<std::string, int> clients;
```

For example:

```
client1 → socket descriptor
client2 → socket descriptor
```

Since multiple threads can access this mapping, a mutex is used to protect it from concurrent access.

---

## 4. Message Routing

Messages can be sent using the following format:

```
@username message
```

For example:

```
@client2 Hello from client1
```

The client extracts the destination username and sends the message to the server. The server looks up that username in its client map and forwards the message to the corresponding socket. The server also prints successfully relayed messages. For example:

```
[CHAT] client1 -> client2 : Hello from client1
```

This is also useful for demonstrating the security problem in Phase 1: the server has direct access to the complete message because the message is still plaintext.

## 5. Client Commands

The client supports the required commands:

```
@username message
```

```
/chat username
```

```
/who
```

```
/quit
```

```
/chat
```

Sets the current chat partner so that the username does not need to be specified for every message.

**/who**

Requests the list of currently connected users from the server.

**/quit**

Terminates the client connection cleanly.

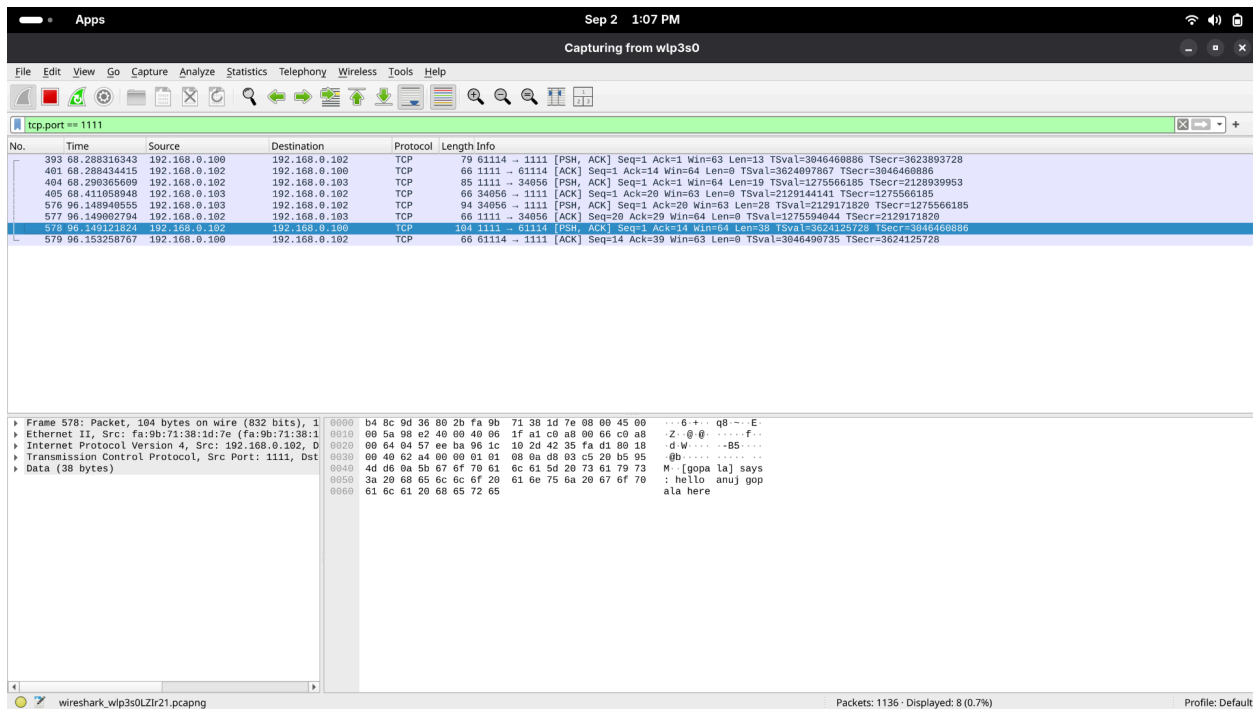
---

## 6. Plaintext Verification

No encryption is used in Phase 1. Messages are therefore transmitted directly over the TCP connection.

The server logs already show the message contents in plaintext. To verify that the same information is visible on the network, traffic was captured using **Wireshark**.

### Figure 1 – Wireshark TCP Stream Showing Plaintext Communication



The capture confirms that someone monitoring the network traffic can read the exchanged messages without needing any decryption.

## Phase 2 – Client-Server Confidentiality Using Diffie-Hellman

### 1. Overview

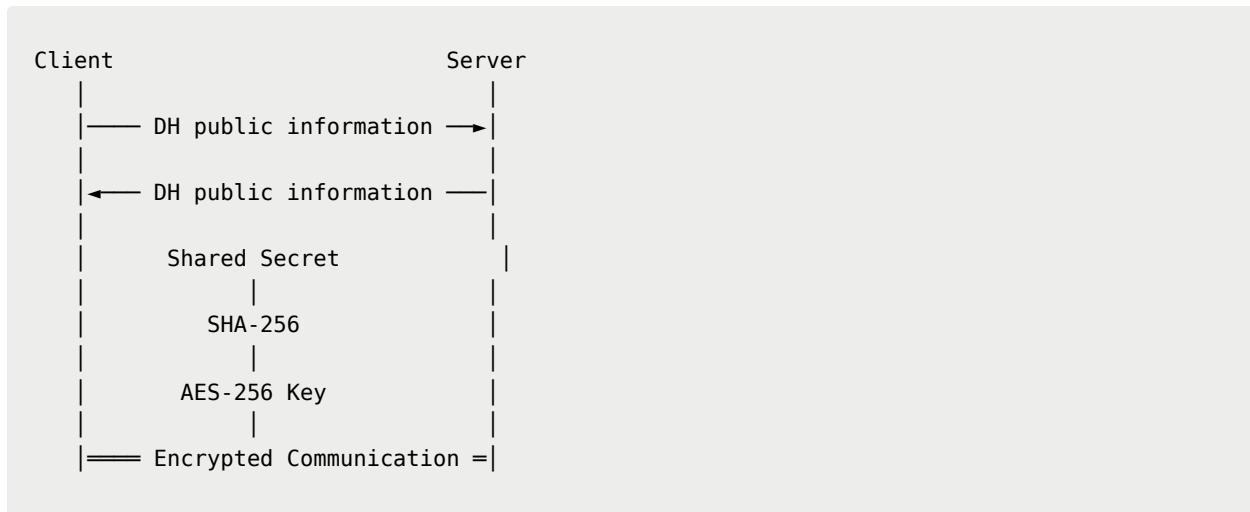
Phase 2 adds confidentiality to the Phase 1 chat application.

A manually implemented **Diffie-Hellman (DH)** key exchange is used to establish a shared secret between each client and the server. The shared secret is then processed using **SHA-256** to derive a 256-bit AES key.

Messages are subsequently encrypted using **AES-256-GCM**.

The DH implementation uses OpenSSL's low-level `BIGNUM` operations and modular exponentiation rather than a built-in DH/ECDH implementation.

The basic flow is:



The same process is performed independently for every client.

## 2. Diffie-Hellman Implementation

The DH functionality is implemented in `dh.cpp`.

The implementation uses the RFC 3526 2048-bit MODP Group (Group 14).

The generator is set to:

```
BN_set_word(g, 2);
```

A private value is generated for each `DHE` instance:

```
BN_rand_range(priv_key, p);
```

The corresponding public value is calculated using modular exponentiation:

```
BN_mod_exp(pub_key, g, priv_key, p, ctx);
```

For a client and server, the exchange can be represented as:

Client:

```
private = a  
public  =  $g^a \bmod p$ 
```

Server:

```
private = b  
public  =  $g^b \bmod p$ 
```

The client computes:

```
 $(g^b)^a \bmod p$ 
```

while the server computes:

```
 $(g^a)^b \bmod p$ 
```

Both calculations produce the same shared secret.

The secret itself is never transmitted over the network.

### 3. Independent Key for Each Client

The server creates a separate `DHE` object for every client connection:

```
void handleClient(int clientSocket) {  
  
    DHE dh;  
  
    dh.generateKeys();  
  
}
```

```
...  
  
}
```

Since `handleClient()` is executed separately for each client, every client performs its own DH exchange with the server.

The server also stores the corresponding `DHE` object along with the client's socket:

```
struct ClientData {  
  
    int socket;  
  
    DHE* dh_ptr;  
  
};
```

This allows the server to use the correct encryption key for each connection.

Conceptually:

```
Client 1 ——— Key K1 ——— Server  
Client 2 ——— Key K2 ——— Server  
  
K1 ≠ K2
```

Thus, the two client connections do not share the same symmetric encryption key.

## 4. Deriving the AES Key

The raw DH shared secret is not directly used as the AES key.

After calculating the shared secret, it is converted into bytes and hashed using SHA-256:



```

EVP_DigestInit_ex(mdctx, EVP_sha256(), nullptr);

EVP_DigestUpdate(
    mdctx,
    secret_bytes.data(),
    secret_bytes.size()
);

EVP_DigestFinal_ex(
    mdctx,
    aes_key.data(),
    &hash_len
);

```

SHA-256 produces 32 bytes:

$32 \text{ bytes} \times 8 = 256 \text{ bits}$

The resulting value is therefore used as the AES-256 key.

The overall process is:



Using SHA-256 also gives a fixed-length representation of the DH shared secret that can be directly used as a symmetric key.

## 5. AES-GCM Encryption

Once the DH exchange is complete, communication is encrypted using **AES-256-GCM**.

A new 12-byte random nonce is generated for every message:

```
unsigned char nonce[12];

RAND_bytes(nonce, sizeof(nonce));
```

AES-256-GCM is then initialized using the derived key and nonce:

```
EVP_EncryptInit_ex(
    ctx,
    EVP_aes_256_gcm(),
    nullptr,
    aes_key.data(),
    nonce
);
```

The encrypted message contains the nonce, authentication tag, and ciphertext:

|                   |                            |            |
|-------------------|----------------------------|------------|
| Nonce<br>12 bytes | Authentication<br>Tag 16 B | Ciphertext |
|-------------------|----------------------------|------------|

The GCM authentication tag allows the receiver to detect if the encrypted data has been modified.

Therefore, AES-GCM provides both:

- Confidentiality
- Integrity/authentication of the ciphertext

---

## 6. Encrypted Login and Chat Communication

The username exchange is also protected after the DH handshake.

For example, the server encrypts its username prompt:

```
std::vector<unsigned char> enc_prompt = dh.encrypt(prompt);
```

The client decrypts the prompt using the derived AES key.

The username entered by the client is also encrypted before being sent:

```
std::vector<unsigned char> enc_username = dh.encrypt(username);
```

Normal application messages and commands are also encrypted, including:

```
@client2 Hello  
  
/who  
  
/quit
```

Therefore, after the initial DH exchange, the actual application data is not transmitted as plaintext.

## 7. DH Fingerprint Verification

A fingerprint is generated from the derived AES key to make it easier to verify that both sides obtained the same key.

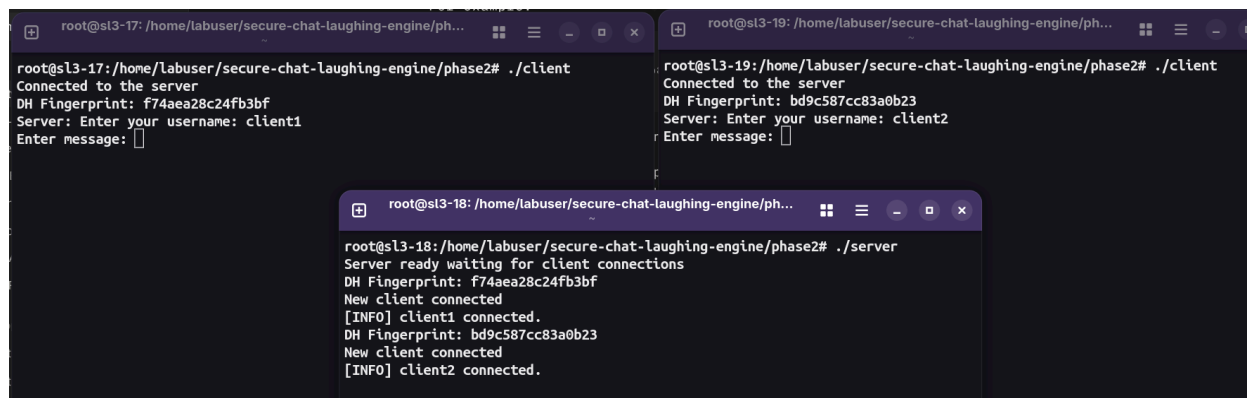
The fingerprint is produced by hashing the AES key and displaying the first eight bytes of the resulting hash.

The actual shared secret and AES key are never printed.

During testing, the fingerprint displayed by the client matched the fingerprint displayed by the server for the corresponding connection.

This provides evidence that both endpoints independently derived the same symmetric key.

**Figure 2 – Matching DH Fingerprints**



```
root@sl3-17: /home/labuser/secure-chat-laughing-engine/phase2# ./client
Connected to the server
DH Fingerprint: f74aea28c24fb3bf
Server: Enter your username: client1
Enter message:

root@sl3-19: /home/labuser/secure-chat-laughing-engine/phase2# ./client
Connected to the server
DH Fingerprint: bd9c587cc83a0b23
Server: Enter your username: client2
Enter message:

root@sl3-18: /home/labuser/secure-chat-laughing-engine/phase2# ./server
Server ready waiting for client connections
DH Fingerprint: f74aea28c24fb3bf
New client connected
[INFO] client1 connected.
DH Fingerprint: bd9c587cc83a0b23
New client connected
[INFO] client2 connected.
```

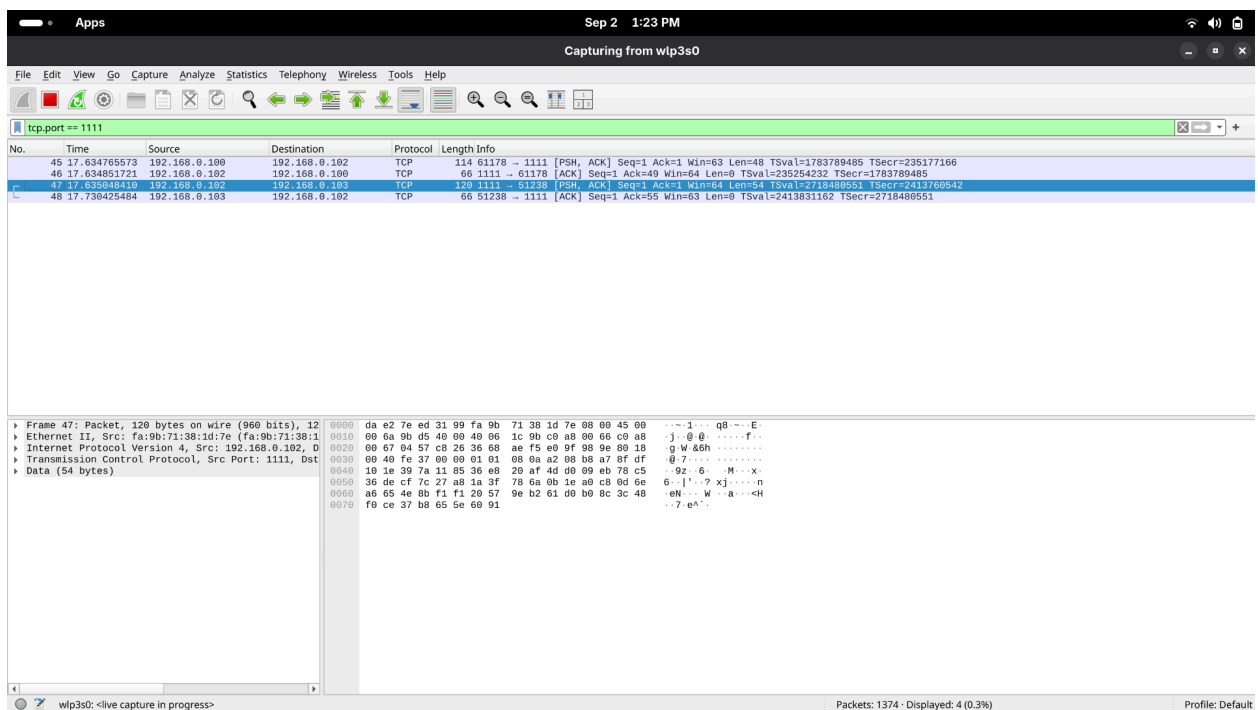
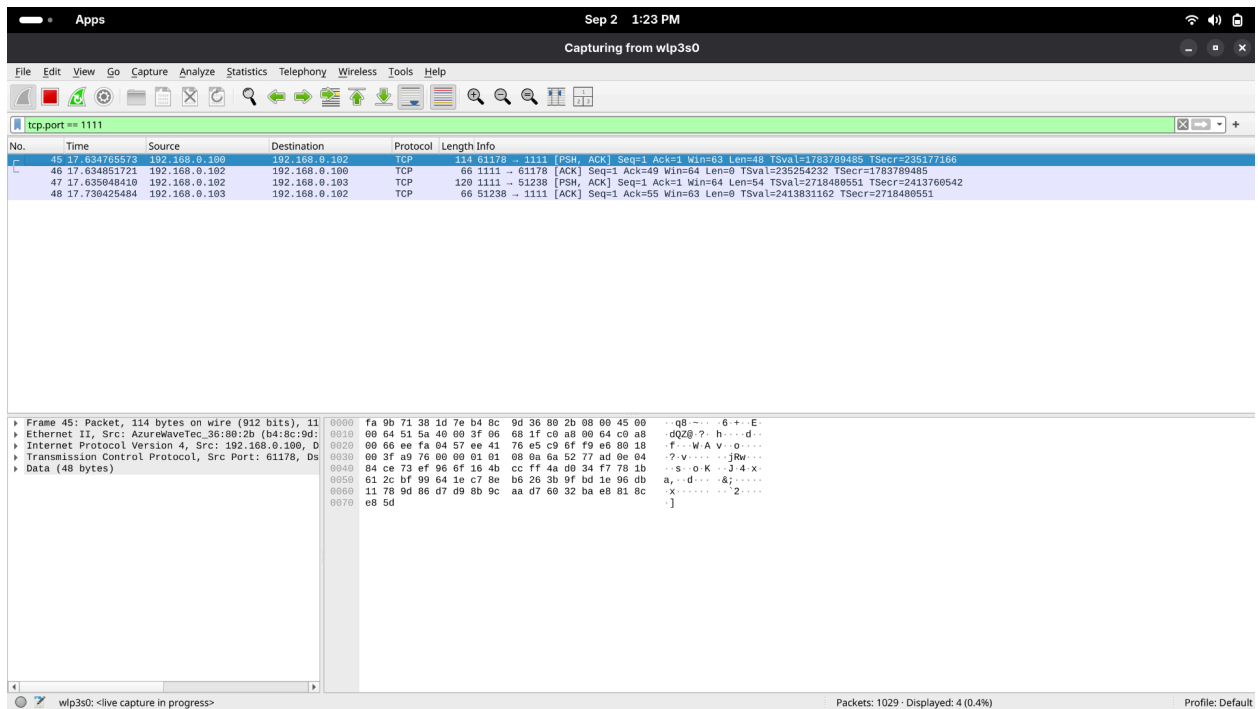
## 8. Wireshark Verification

The Phase 1 traffic capture was repeated after adding encryption.

The traffic was captured using Wireshark on TCP port 1111 and inspected using:

In Phase 2, the application data appears as binary-looking encrypted data rather than readable chat messages.

**Figure 3 – Wireshark Showing Encrypted Phase 2 Traffic**



This shows that a passive observer monitoring the network can no longer directly read the chat messages from the captured TCP traffic.

## 9. AES-GCM Tamper Detection

AES-GCM also protects the integrity of the encrypted message.

To test this, one byte of the ciphertext was modified before attempting to decrypt it.

The decryption process verifies the GCM authentication tag:

```
EVP_CIPHER_CTX_ctrl(  
    ctx,  
    EVP_CTRL_GCM_SET_TAG,  
    16,  
    tag  
);
```

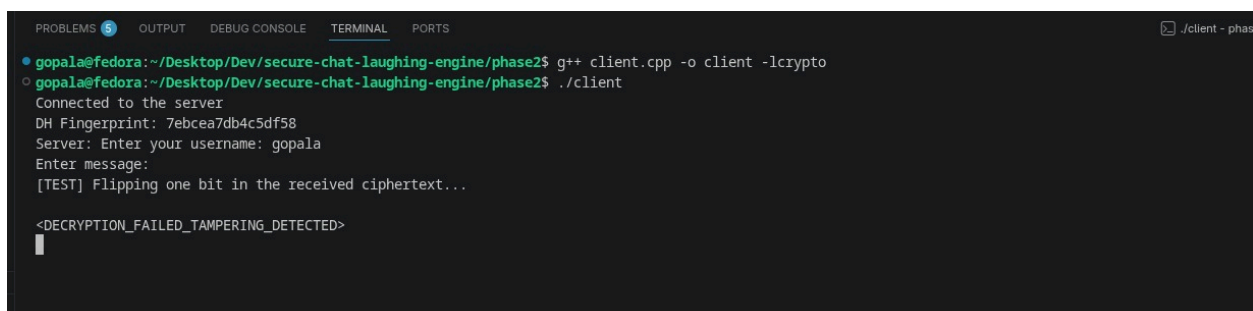
If the ciphertext has been modified, authentication fails and the message is rejected:

```
if (ret <= 0) {  
    return "<DECRYPTION_FAILED_TAMPERING_DETECTED>";  
}
```

The observed output was:

```
<DECRYPTION_FAILED_TAMPERING_DETECTED>
```

### Figure 4 – AES-GCM Tampering Test



```
PROBLEMS 5 OUTPUT DEBUG CONSOLE TERMINAL PORTS .client - phas  
gopala@fedora:~/Desktop/Dev/secure-chat-laughing-engine/phase2$ g++ client.cpp -o client -lcrypto  
gopala@fedora:~/Desktop/Dev/secure-chat-laughing-engine/phase2$ ./client  
Connected to the server  
DH Fingerprint: 7ebcea7db4c5df58  
Server: Enter your username: gopala  
Enter message:  
[TEST] Flipping one bit in the received ciphertext...  
  
<DECRYPTION_FAILED_TAMPERING_DETECTED>  
█
```

The test confirms that modification of the encrypted data is detected rather than being silently accepted.

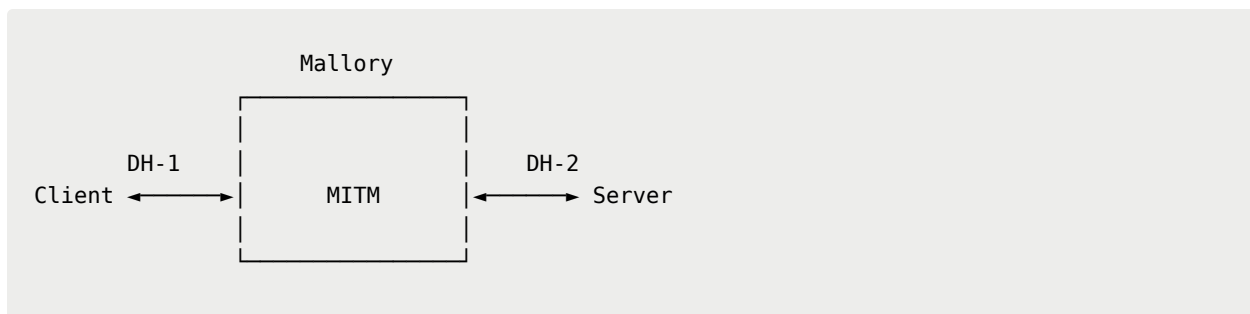
---

## 10. Man-in-the-Middle Attack

Although DH protects against passive eavesdropping, the basic DH exchange does not authenticate who is participating in the exchange.

To demonstrate this limitation, a separate `mitm.cpp` proxy was implemented.

The proxy performs two independent DH exchanges:



This results in two different keys:

Client ↔ Mallory : Key K1

Mallory ↔ Server : Key K2

The client believes it has established a secure connection with the server, while the server believes it has established a secure connection with the client.

Mallory, however, has access to both keys.

---

## 11. MITM Message Interception

The proxy decrypts messages received from the client using the client-facing key:

```
std::string plaintext =  
    dh_client->decrypt(payload);
```

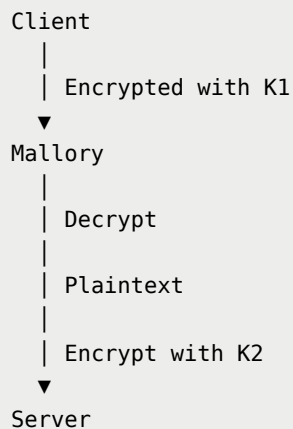
The decrypted message is then logged:

```
std::cout << "\n[INTERCEPT C->S]: "  
    << plaintext << std::endl;
```

Mallory then encrypts the plaintext using the server-facing key and forwards it to the real server.

The same process happens for messages travelling from the server back to the client.

The attack can therefore be represented as:



**Figure 5 – MITM Proxy Intercepting Plaintext**



```

dibyansh@LAPTOP-3AF6P4N9:/mnt/c/Users/HP/Desktop/Assignments/dev - network/secure-chat-laughing-engine/phase2$ ./client
Connected to the server
DH Fingerprint: 436dca84a9403d70
Server: Enter your username: dibyansh_gupta
Enter message: /who
Enter message:

--- Online Users ---
- dibyansh_gupta
- anuj_ramane
-----

/chat anuj_ramane
Chat partner set to anuj_ramane
Enter message: hello anuj how are you
Enter message:

```

```

75     ... DHE dh_server_facing;
76     ... DHE dh_client_facing;

PROBLEMS OUTPUT DEBUG CONSOLE TERMINAL PORTS
hedwig69@fedora:~/Desktop/IIT-Bombae/Semester3/CS6008 - Network Security/Secure_Chat_Assignment/phase2$ ./server
Server ready waiting for client connections
DH Fingerprint: 436dca84a9403d70
New client connected
DH Fingerprint: 77ad40861c2dcfee
New client connected
[INFO] anuj_ramane connected.
[INFO] dibyansh_gupta connected.
[CHAT] dibyansh_gupta -> anuj_ramane : hello anuj how are you

```

```

105     std::thread t1(relay_client_to_server, client_fd, server_fd, &dh_client_facing, &dh_server_facing);
106

PROBLEMS OUTPUT DEBUG CONSOLE TERMINAL PORTS
gopala@fedora:~/Desktop/Dev/secure-chat-laughing-engine/phase2$ ./
client      client_normal client_victim mitm      server
gopala@fedora:~/Desktop/Dev/secure-chat-laughing-engine/phase2$ ./mitm
[MITM] Connected to real Server.
[MITM] Waiting for victim client on port 9999...
[MITM] Victim Client connected!
[MITM] Handshakes complete. Logging traffic...

[INTERCEPT S->C]: Server: Enter your username:

[INTERCEPT C->S]: anuj_ramane

[INTERCEPT S->C]:
[dibyansh_gupta] says: hello anuj how are you

```

```

Problems 6 Output Debug Console Terminal Ports
ws1 - pha

anujr@AnujASUS:/mnt/c/Users/anujr/Downloads/dev/secure-chat-laughing-engine/phase2$ g++ client.cpp -o client -lcrypto
anujr@AnujASUS:/mnt/c/Users/anujr/Downloads/dev/secure-chat-laughing-engine/phase2$ ./client
Connected to the server
DH Fingerprint: 40d26dba87280c38
Server: Enter your username: anuj_ramane
Enter message:

[dibyansh_gupta] says: hello anuj how are you

```

This shows that unauthenticated DH alone is vulnerable to an active MITM attack.

---

## 12. Phase 2 Result

Phase 2 adds confidentiality and authenticated encryption to the chat application.

Each client independently performs a DH exchange with the server and derives its own AES-256 key. Messages are then protected using AES-256-GCM.

The following tests were performed:

- Matching DH fingerprints on both endpoints
- Wireshark inspection of encrypted traffic
- AES-GCM ciphertext tampering
- MITM interception using the Phase 2 proxy

The Wireshark capture confirms that the application messages are no longer visible as plaintext, and the tampering test shows that modified ciphertext is rejected.

However, the MITM experiment exposes a limitation of plain DH: **the protocol establishes a shared secret but does not prove the identity of the other party.**

This is the problem addressed in Phase 3.

---

## Phase 3 – Server Authentication Using PKI

### Objective

Phase 3 adds server authentication using **Public Key Infrastructure (PKI)**.

The client now verifies that it is communicating with the legitimate server before continuing with the Diffie-Hellman exchange.

The authentication process has two parts:

1. Certificate validation
2. Proof-of-possession of the server's private key

Only after both checks succeed does the client continue with the DH exchange.

---

## 1. Certificate Authority and Server Certificate Setup

A private Certificate Authority was created using OpenSSL.

The CA consists of:

- A private CA key
- A self-signed CA certificate

A separate server key pair was then generated. A Certificate Signing Request (CSR) was created from the server public key and signed by the CA.

The resulting files are:

```
certs/  
├─ ca.key  
├─ ca.crt  
├─ server.key  
└─ server.crt
```

The following commands were used.

### Generate the CA private key

```
openssl genrsa -out certs/ca.key 4096
```

## Generate the self-signed CA certificate

```
openssl req -x509 -new -nodes \  
    -key certs/ca.key \  
    -sha256 -days 3650 \  
    -out certs/ca.crt \  
    -subj "/C=IN/ST=Maharashtra/L=Mumbai/O=SecureChat/OU=CA/CN=SecureChat Root CA"
```

## Generate the server private key

```
openssl genrsa -out certs/server.key 2048
```

## Generate the server CSR

```
openssl req -new \  
    -key certs/server.key \  
    -out certs/server.csr \  
    -subj "/C=IN/ST=Maharashtra/L=Mumbai/O=SecureChat/OU=Server/CN=SecureChat Server"
```

## Sign the server CSR using the CA

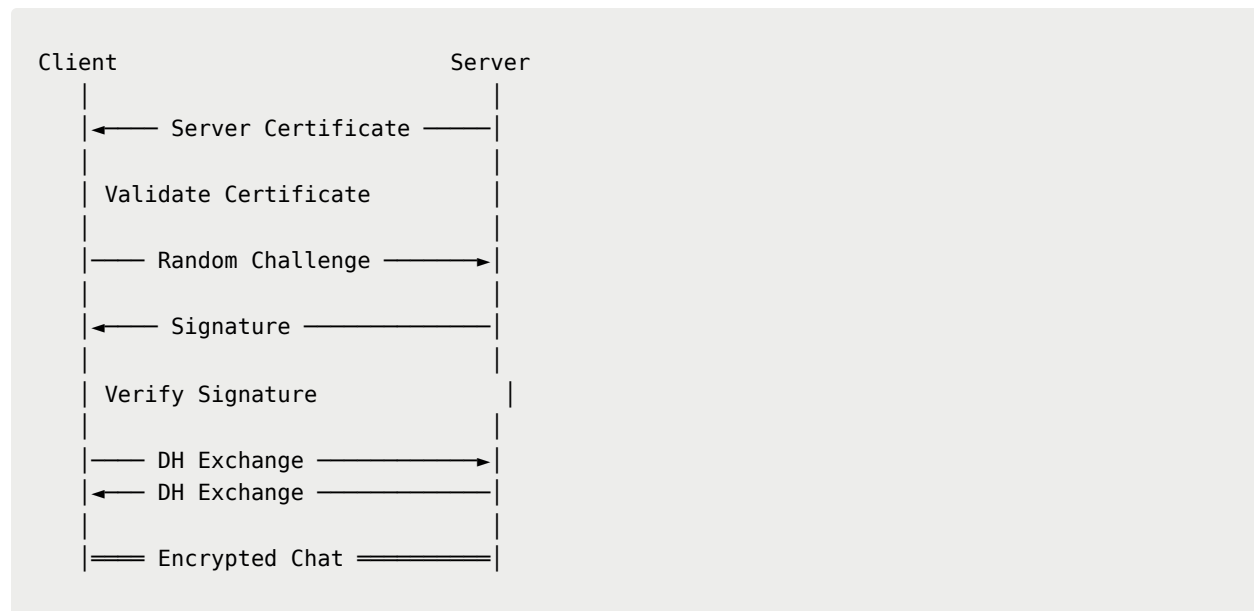
```
openssl x509 -req \  
    -in certs/server.csr \  
    -CA certs/ca.crt \  
    -CAkey certs/ca.key \  
    -CAcreateserial \  
    -out certs/server.crt \  
    -days 365
```

```
-days 365 \  
-sha256
```

## 2. Updated Client and Server

The Phase 2 client and server were modified to add certificate authentication before the DH exchange.

The new handshake is:



### 2.1 Certificate Validation

Before performing DH, the server sends its certificate to the client.

The client receives the certificate and validates it against the trusted CA certificate:

```
certs/ca.crt
```

The client checks that the certificate is:

- Signed by the trusted CA
- Within its validity period
- Valid according to the configured trust store

If certificate validation fails, the client closes the connection and does not continue with the DH exchange.

This prevents an attacker from simply presenting an arbitrary certificate to the client.

---

## 2.2 Proof-of-Possession

Certificate validation alone is not sufficient.

An attacker could potentially obtain a copy of the legitimate server certificate. However, the attacker should not be able to authenticate without the corresponding private key.

To test this, the client generates a random 32-byte challenge:

```
Client → Server : Random Challenge
```

The legitimate server signs the challenge using:

```
certs/server.key
```

The signature is sent back to the client:

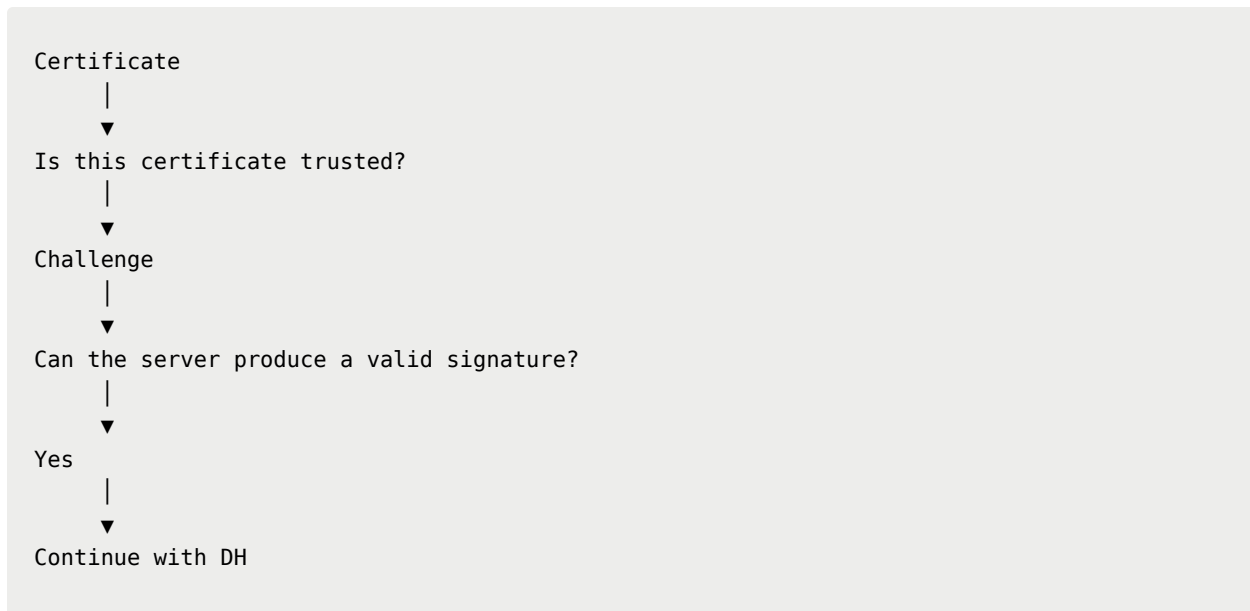
```
Client → Server : Challenge
```

```
Client ← Server : Signature(Challenge)
```

The client extracts the public key from the already-validated server certificate and uses it to verify the signature.

Only if the signature verification succeeds does the client continue with the DH exchange.

In other words:



## 2.3 Legitimate Phase 3 Connection

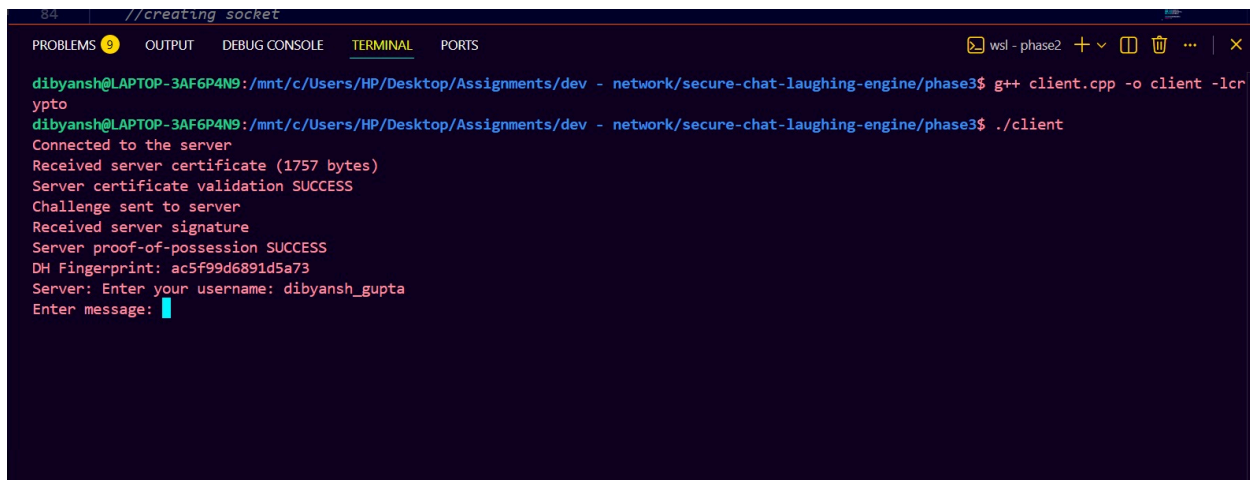
A legitimate connection was tested using the real server certificate and corresponding private key.

The client output showed successful certificate validation and proof-of-possession before the DH exchange continued.

**Figure 7 – Legitimate Phase 3 Connection**

```
hedwig69@fedora:~/Desktop/IIT-Bombay/Semester3/CS6008 - Network Security/Secure_Chat_Assignment/phase3$ ./server
Server ready waiting for client connections
Failed to receive challenge
Challenge received from client
Challenge signed and signature sent to client
DH Fingerprint: ac5f99d6891d5a73
New client connected
[INFO] dibyansh_gupta connected.
```

The screenshot shows a terminal window with the output of the `./server` command. The output indicates that the server is ready, receives a challenge, signs it, and sends it to the client. It also shows the DH fingerprint and that a new client (dibyansh\_gupta) has connected.



```
84 //creating socket
PROBLEMS OUTPUT DEBUG CONSOLE TERMINAL PORTS
dibyansh@LAPTOP-3AF6P4N9:/mnt/c/Users/HP/Desktop/Assignments/dev - network/secure-chat-laughing-engine/phase3$ g++ client.cpp -o client -lcr
ypt
dibyansh@LAPTOP-3AF6P4N9:/mnt/c/Users/HP/Desktop/Assignments/dev - network/secure-chat-laughing-engine/phase3$ ./client
Connected to the server
Received server certificate (1757 bytes)
Server certificate validation SUCCESS
Challenge sent to server
Received server signature
Server proof-of-possession SUCCESS
DH Fingerprint: ac5f99d6891d5a73
Server: Enter your username: dibyansh_gupta
Enter message:
```

The screenshot should show output similar to:

```
Received server certificate
Server certificate validation SUCCESS
Challenge sent to server
Received server signature
Server proof-of-possession SUCCESS
DH Fingerprint: ...
```

### 3. Updated MITM Attack

The MITM proxy from Phase 2 was modified to attack the Phase 3 protocol.

In the first attack, Mallory generates a different certificate that is **not signed by the trusted CA**.

Mallory sends this certificate to the victim client.

The client attempts to validate the certificate using:



```
certs/ca.crt
```

Since Mallory's certificate was not issued by the trusted CA, certificate validation fails.

The client then closes the connection before the DH exchange can take place.

The expected behaviour is:

## Figure 8 – MITM Attack Fails Due to Invalid Certificate

```
anujr@AnujASUS:/mnt/c/Users/anujr/Downloads/dev/secure-chat-laughing-engine/phase3$ ./client
Connected to the server
Received server certificate (1757 bytes)
Server certificate validation SUCCESS
Challenge sent to server
Received server signature
SERVER PROOF-OF-POSSESSION FAILED
anujr@AnujASUS:/mnt/c/Users/anujr/Downloads/dev/secure-chat-laughing-engine/phase3$
```

## 4. Proof-of-Possession Bypass Attempt

A second attack was performed to test whether an attacker could bypass authentication simply by obtaining a copy of the legitimate server certificate.

In this attack, Mallory possesses:

```
server.crt
```

but does **not** possess:

```
server.key
```

Mallory forwards the legitimate server certificate to the client. Because the certificate is valid and trusted, the certificate validation step succeeds.

The client then generates a random challenge.

Mallory attempts to sign the challenge using a different private key.

The client verifies the received signature using the public key contained in the legitimate server certificate.

Since Mallory's private key does not correspond to the public key in the certificate, verification fails.

The client therefore rejects the connection.

Expected output:

```
Received server signature  
  
SERVER PROOF-OF-POSSESSION FAILED
```

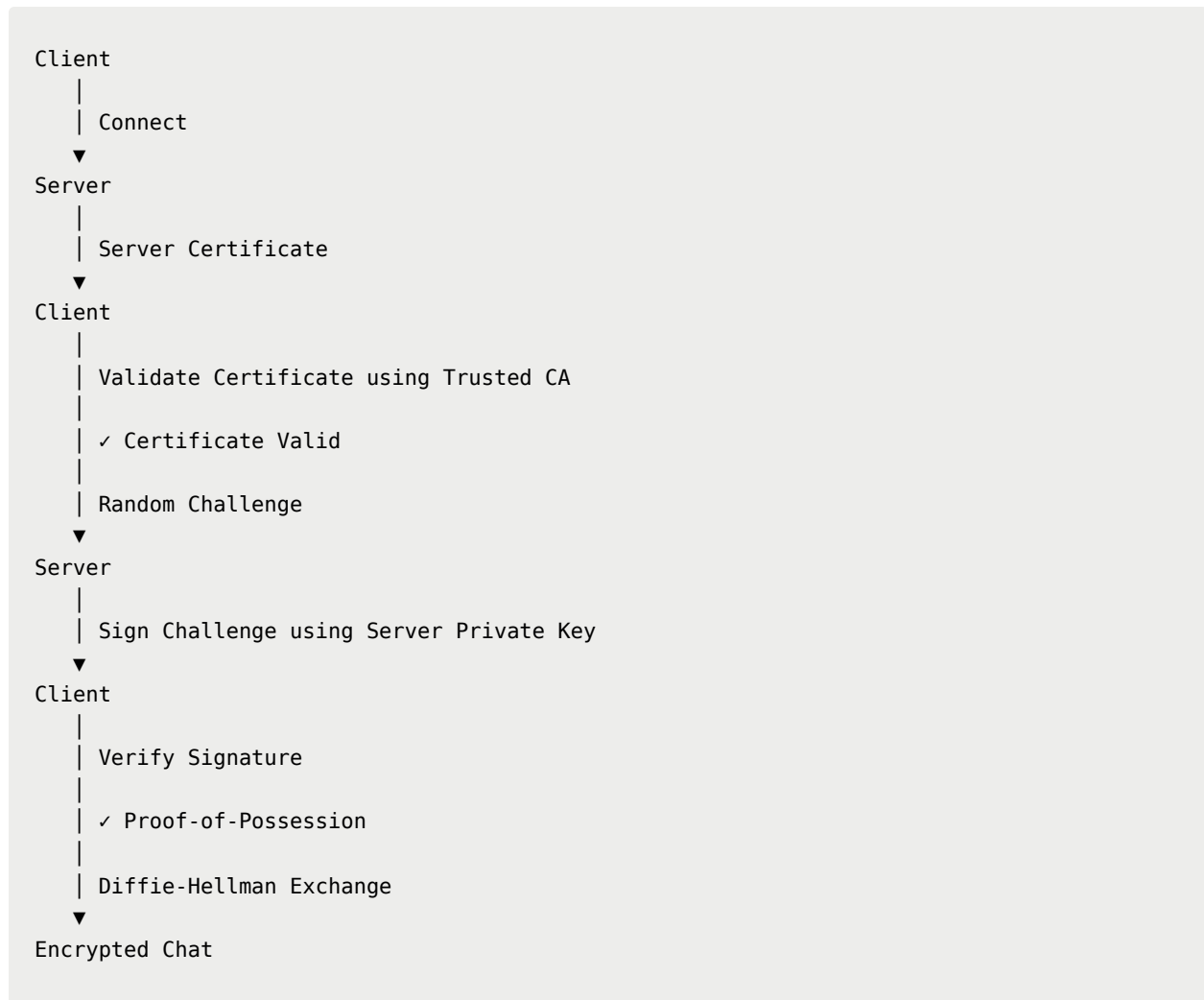
## Figure 9 – Proof-of-Possession Bypass Attempt Rejected

```
gopala@fedora:~/Desktop/Dev/secure-chat-laughing-engine/phase3$ ./mitm_adv  
[MITM] Connected to real server.  
[MITM] Waiting for victim client on port 9999...  
[MITM] Victim client connected!  
[MITM] Captured legitimate server certificate (1757 bytes)  
[MITM] Forwarded legitimate certificate to victim.  
[MITM] Loaded Mallory's DIFFERENT private key.  
[MITM] Received client's challenge.  
[MITM] Signed challenge using WRONG private key.  
[MITM] Sent bogus signature to victim.  
[MITM] Victim closed the connection.  
[MITM] Proof-of-possession successfully blocked the attack!  
gopala@fedora:~/Desktop/Dev/secure-chat-laughing-engine/phase3$
```

This test is important because it shows that simply possessing a valid certificate is not enough. The server must also demonstrate possession of the corresponding private key.

## 5. Phase 3 Security Flow

The final Phase 3 handshake can be summarized as follows:



The important difference from Phase 2 is that the DH exchange is no longer performed with an unauthenticated peer.

## 6. Phase 3 Result

Phase 3 adds server authentication to the secure chat application using PKI.

The client now performs two authentication checks before establishing the encrypted session:

1. **Certificate validation** – verifies that the server certificate was issued by the trusted CA.
2. **Proof-of-possession** – verifies that the server actually possesses the private key corresponding to the certificate.

The legitimate server passes both checks and is then allowed to proceed with the DH exchange.

The modified MITM proxy was tested in two ways:

- Using an untrusted certificate – rejected during certificate validation.
- Using the legitimate certificate without the corresponding private key – rejected during proof-of-possession.

Therefore, the Phase 2 MITM attack is no longer successful against the Phase 3 authentication mechanism.

The main security improvement introduced in this phase is that the client can now **authenticate the server before trusting the DH key exchange**.

## Phase 4 – End-to-End Encryption Between Clients

### 1. Overview

Phase 4 adds an additional end-to-end encryption layer between clients.

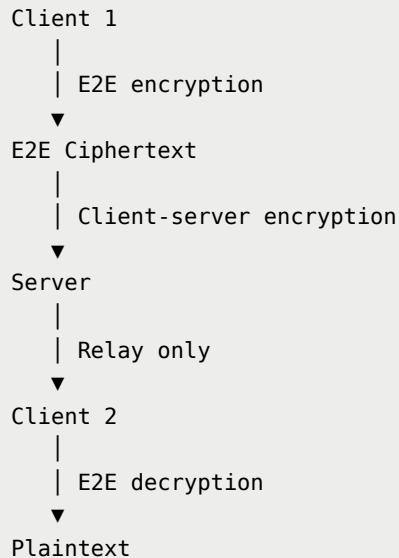
When Client 1 executes:

```
/e2e client2
```

Client 1 and Client 2 perform a separate Diffie-Hellman exchange directly at the application level. The server only relays the

handshake messages and does not obtain the resulting shared key. Once the E2E session is established, chat messages are encrypted using the client-to-client key before being sent through the existing encrypted client-server connection from Phase 3.

The resulting structure is:



The server can still see routing information such as the sender and destination username, but it cannot derive the E2E key or decrypt the message content.

## 2. E2E Key Establishment

The `/e2e username` command triggers the client-to-client key exchange.

The protocol distinguishes E2E handshake messages from normal chat messages using tags such as:

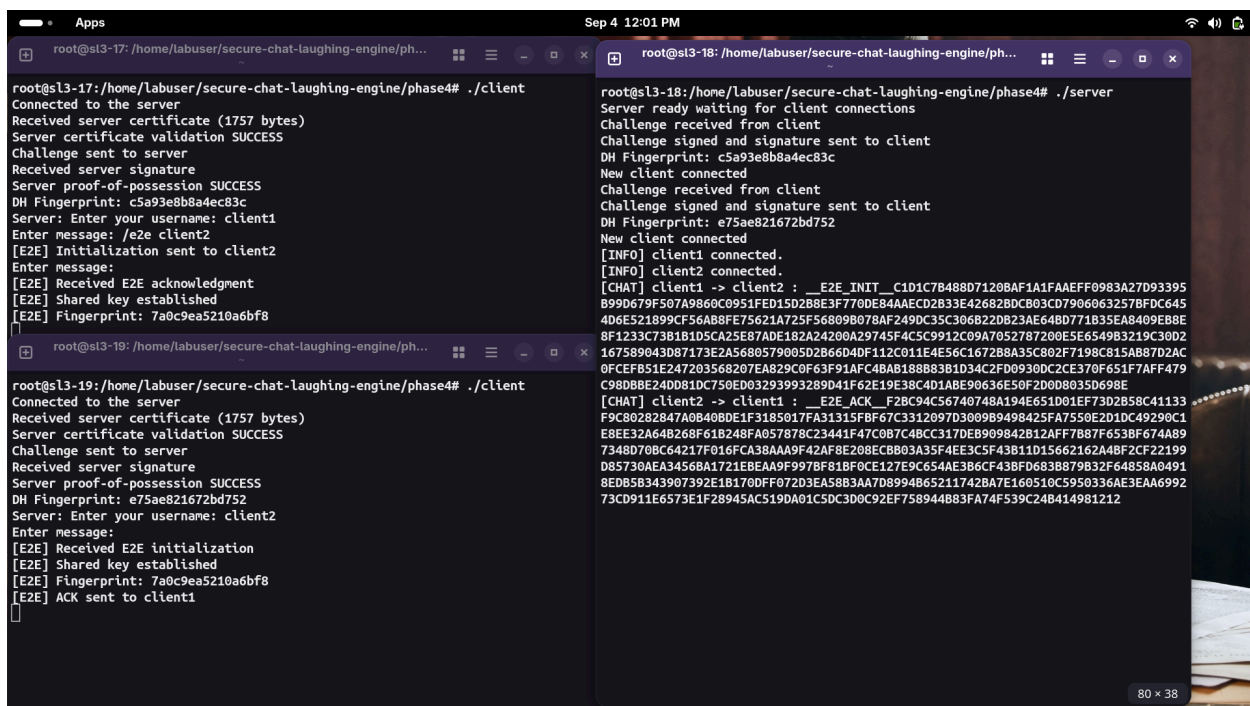
```
__E2E_INIT__  
__E2E_ACK__
```

\_\_E2E\_MSG\_\_

The server does not need to understand these messages cryptographically. It simply forwards them to the appropriate client.

After the exchange, both clients independently derive the same E2E key.

**Figure 10 – Matching E2E Fingerprints**



The image shows three terminal windows from a macOS desktop environment. The top-left window (root@sl3-17) shows a client connecting to a server, receiving a certificate, and sending a challenge. The top-right window (root@sl3-18) shows the server waiting for connections, receiving a challenge from the client, and sending a signed challenge back. The bottom window (root@sl3-19) shows a second client connecting, receiving a certificate, and sending a challenge. The output in the bottom window shows the client receiving the E2E initialization, shared key, and fingerprint from the server, and then sending an ACK back to the client1.

```
root@sl3-17: /home/labuser/secure-chat-laughing-engine/phase4# ./client
Connected to the server
Received server certificate (1757 bytes)
Server certificate validation SUCCESS
Challenge sent to server
Received server signature
Server proof-of-possession SUCCESS
DH Fingerprint: c5a93e8b8a4ec83c
Server: Enter your username: client1
Enter message: /e2e client2
[E2E] Initialization sent to client2
Enter message:
[E2E] Received E2E acknowledgment
[E2E] Shared key established
[E2E] Fingerprint: 7a0c9ea5210a6bf8

root@sl3-18: /home/labuser/secure-chat-laughing-engine/phase4# ./server
Server ready waiting for client connections
Challenge received from client
Challenge signed and signature sent to client
DH Fingerprint: c5a93e8b8a4ec83c
New client connected
Challenge received from client
Challenge signed and signature sent to client
DH Fingerprint: e75ae821672bd752
New client connected
[INFO] client1 connected.
[INFO] client2 connected.
[CHAT] client1 -> client2 : __E2E_INIT_C1D1C7B488D7120BAF1A1FAAEFF0983A27D93395
B99D679F507A9860C0951FED15D2B8E3F770DE84AAEC2833E42682BDCB03CD7906063257BFDC645
4D6E521899CF56AB8FE75621A725F56809B078AF249DC35C3068220B23AE64BD771B35EA8409E88E
8F1233C73B181D5CA25E87ADE182A24200A29745F4C5C9912C09A7052787200E5E654983219C3802
167589043D87173E2A5680579005D2B66D4DF112C011E4E56C1672B8A35C802F7198C815A887D2AC
0FCEFB51E247203568207EAB29C0F63F91AFC48AB188883B1D34C2FD0930DC2CE370F651FAFF479
C98DBBE24DD81DC750ED03293993289D41F62E19E38C4D1ABE90636E50F2D0D80350698E
[CHAT] client2 -> client1 : __E2E_ACK_F2B8C94C56740748A194E651D01EF73D2B58C41133
F9C80282847A0B40BDE1F3185017FA31315FBF67C3312097D3009B9498425FA7550E2D1DC49290C1
E8EE32A648268F61B248FA057878C23441F47C0B7C48CC317DEB909842B12AFF7B87F653BF674A89
7348D70BC64217F016FCA38AAA9F42AF8E208ECB03A35F4EE3C5F43B11D15662162A48F2CF22199
D85730AEA3456BA1721EBEAA9F997BF818F0CE127E9C654AE3B6CF43BF6838879832F64858A0491
8ED5B343907392E1B1700FF072D3EA58B3AA7D8994865211742BA7E160510C5950336AE3EAA6992
73CD911E6573E1F28945AC519DA01C5DC300C92EF758944883FA74F539C24B414981212

root@sl3-19: /home/labuser/secure-chat-laughing-engine/phase4# ./client
Connected to the server
Received server certificate (1757 bytes)
Server certificate validation SUCCESS
Challenge sent to server
Received server signature
Server proof-of-possession SUCCESS
DH Fingerprint: e75ae821672bd752
Server: Enter your username: client2
Enter message:
[E2E] Received E2E initialization
[E2E] Shared key established
[E2E] Fingerprint: 7a0c9ea5210a6bf8
[E2E] ACK sent to client1
```

The matching fingerprints provide evidence that both clients derived the same E2E key.

### 3. End-to-End Message Encryption

After the E2E session is established, messages are encrypted using the client-to-client key and AES-GCM.

The resulting ciphertext is wrapped using:

\_\_E2E\_MSG\_\_

and sent through the already encrypted client-server connection. The server therefore receives only opaque E2E ciphertext.

### Figure 11 – Server Relaying E2E Ciphertext

The server can identify that `client1` is sending data to `client2`, but the actual message content is not visible.

For comparison, before an E2E session is established, the server can still read normal chat messages, consistent with the Phase 2/3 design.

---

## 4. End-to-End Verification

A test message was sent from Client 1 to Client 2 after establishing the E2E session.

The server log showed only the E2E ciphertext, while Client 2 successfully decrypted and displayed the original message.

### Figure 12 – E2E Message Successfully Decrypted

```
root@sl3-17: /home/labuser/secure-chat-laughing-engine/phase4# ./client
Connected to the server
Received server certificate (1757 bytes)
Server certificate validation SUCCESS
Challenge sent to server
Received server signature
Server proof-of-possession SUCCESS
DH Fingerprint: c5a93e8b8a4ec83c
Server: Enter your username: client1
Enter message: /e2e client2
[E2E] Initialization sent to client2
Enter message:
[E2E] Received E2E acknowledgment
[E2E] Shared key established
[E2E] Fingerprint: 7a0c9ea5210a6bf8
hello client2 how are you
Enter message:

Server proof-of-possession SUCCESS
DH Fingerprint: e75ae821672bd752
Server: Enter your username: client2
Enter message:
[E2E] Received E2E initialization
[E2E] Shared key established
[E2E] Fingerprint: 7a0c9ea5210a6bf8
[E2E] ACK sent to client1

[E2E MESSAGE] hello client2 how are you
[]

root@sl3-18: /home/labuser/secure-chat-laughing-engine/phase4# ./server
Server ready waiting for client connections
Challenge received from client
Challenge signed and signature sent to client
DH Fingerprint: c5a93e8b8a4ec83c
New client connected
Challenge received from client
Challenge signed and signature sent to client
DH Fingerprint: e75ae821672bd752
New client connected
[INFO] client1 connected.
[INFO] client2 connected.
[CHAT] client1 -> client2 : _E2E_INIT_C1D1C7B488D7120BAF1A1FAAEFF0983A27D93395
399D679F507A9860C0951FED15D2B8E3F770DE84AAECD2B33E42682BDC803CD7906063257BFD6C45
4D6E521899CF56AB8FE75621A725F56809B078AF249DC35C306B220B23AE64BD771B35EA8409EB8E
3F1233C73B1B1D5CA25E87ADE182A24200A29745F4C5C9912C09A7052787200E5E6549B3219C30D2
167589043D87173E2A5680579005D2B66D4DF112C011E4E56C167288A35C802F7198C815AB87D2AC
3FCEFB51E247203568207EA829C0F63F91AF4C4B8B188B83B1D34C2FD0930DC2CE370F651F7AFF479
C98DBBE24D081DC750ED03293993289D41F62E19E38C4D1ABE90636E50F2D0D80350698E
[CHAT] client2 -> client1 : _E2E_ACK_F28C94C56740748A194E651D01EF73D2B58C41133
F9C80282847A0B40BDE1F3185017FA31315FBF67C3312097D3009B9498425FA7550E2D1DC49290C1
EBEE32A648268F61B248FA057878C23441F47C0B7C4BCC317DEB909842B12AFF7B87F653BF674A89
7348D70BC64217F016FCA38AA9F42AF8E208ECBB03A35F4EE3C5F43B11D15662162A4BF2CF22199
D85730AEA3456BA1721EBEAA9F997BF81BF0CE127E9C654AE3B6CF43BF0683B879B32F64858A0491
8EDB5B343907392E1B170DFF072D3EA58B3AA7D8994865211742BA7E160510C5950336AE3EAA6992
73CD911E6573E1F28945AC519DA01C5DC3D0C92EF758944883FA74F539C248414981212
[CHAT-E2E] client1 -> client2 : _E2E_MSG_C85E3B92559A3F39E66D025BF3DA7DE09B23
8EDB2A6A7C7151FCEBA916923773BD0B009C0855860C6712031D7AC8559888B133F5F
[]
```

- This confirms that:
- Client 1 and Client 2 successfully established a shared E2E key.
  - The server could not read the E2E message content.
  - The server continued to function purely as a relay.
  - Client 2 could correctly decrypt the message.

## 5. Phase 4 Result

Phase 4 introduces an additional encryption layer between clients without replacing the existing client-server security from Phase 3.

The server continues to provide routing and transport, but it does not possess the client-to-client E2E key. The matching fingerprints demonstrate that the two clients independently derived the same key, while the server log demonstrates that E2E chat content is transmitted only as opaque ciphertext.



Thus, the confidentiality of messages is extended from **client-server encryption** to **true client-to-client end-to-end encryption**.

## Appendix A – Generative AI Usage

Some of the prompts that were used during the development of the assignment:

### Phase 1 – Baseline Chat Application

- Explain how to implement a one-to-one chat application using TCP sockets in C++.
- Help me understand how the client and server should communicate in a TCP chat application.
- Help me fix this problem in TCP socket chat application.

### 2 Phase 2 – Diffie-Hellman and AES-GCM

- Explain how Diffie-Hellman key exchange works and how it can be implemented using OpenSSL BIGNUM.
- Help me implement Diffie-Hellman manually using RFC 3526 Group 14 without using OpenSSL's built-in DH/ECDH APIs.
- How can I derive an AES-256 key from the Diffie-Hellman shared secret using SHA-256?
- Help me implement AES-256-GCM encryption and decryption using OpenSSL.
- Help me implement a MITM proxy to demonstrate the vulnerability in the unauthenticated Diffie-Hellman exchange.

- Help me troubleshoot AES-GCM decryption and tamper detection.

### **3 Phase 3 – PKI and Server Authentication**

- Explain how to create a Certificate Authority and issue a server certificate using OpenSSL.
- Help me implement server certificate validation in the C++ client using OpenSSL.
- How can I verify that a server possesses the private key corresponding to its certificate?
- Help me implement a challenge-response proof-of-possession mechanism using OpenSSL signatures.
- Help me update the MITM attack so that it fails against certificate validation and proof-of-possession.
- Help me troubleshoot certificate validation and signature verification errors.

### **4 Phase 4 – End-to-End Encryption**

- Explain how to modify the existing chat application to provide end-to-end encryption between clients while the server only relays encrypted messages.
- Help me implement a separate Diffie-Hellman exchange between two clients while maintaining the existing client-server encrypted connection.
- How should E2E\_INIT, E2E\_ACK, and E2E\_MSG messages be handled?
- Help me troubleshoot why the E2E acknowledgement is not being received by the initiating client.
- Why can simultaneous E2E key exchanges cause the two clients to derive different keys?
- Review my client.cpp and identify the issue with the E2E handshake.

- Can the E2E implementation be fixed without introducing TCP message framing?

## 5 Troubleshooting and Testing

- Help me troubleshoot this OpenSSL compilation error: fatal error: openssl/bn.h: No such file or directory.
- Help me troubleshoot SSH key and host-key issues on the lab machines.
- Help me understand what the Wireshark packet capture demonstrates about confidentiality.
- What evidence should I include in the report to demonstrate that the MITM attack succeeds or fails?
- Review my implementation and suggest what should be tested for each security phase.

## 6 Report Preparation

- Help me structure the Network Security assignment report.
- Rewrite my Phase 1 implementation description in a clear technical style.
- Help me explain the security improvements between each phase.
- What screenshots and evidence should be included in the report?
- Help me write the discussion of security properties and limitations.